SPIKA TECH™

POLÍTICA DE CONTRASEÑAS

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 PREÁMBULO 4
3 POLÍTICA DE CONTRASEÑAS 4
4 REFERENCIAS 8

1 OBJETIVO

Esta política establece los requisitos mínimos que deberán tener las contraseñas que se empleen en aquellos Sistemas de Información que pertenezcan a SPIKA TECH.

2 PREÁMBULO

Esta política será de obligatorio cumplimiento para todo el personal y sistemas de información relacionados con los dominios citados en la descripción, que tengan implantado el uso de contraseñas dentro de alguno de los métodos de autenticación empleados para acceder y operar con ellos.

3 POLÍTICA DE CONTRASEÑAS

Gestión y características de las contraseñas

Una vez que una entidad, usuario o proceso haya sido debidamente autorizado a acceder a un sistema de información se procederá a generar un identificador singular que permita conocer el destinatario del mismo, así como los derechos de acceso que recibe.

Esto significa que no está permitido el uso de identificación de usuario y contraseñas que vengan por defecto en los Sistemas de Información, siendo necesaria su eliminación antes de poner el equipo en servicio.

Una vez generada la contraseña inicial, esta deberá ser comunicada al usuario empleando un canal seguro de comunicación donde se garantice la confidencialidad de la comunicación transmitida, preferiblemente se utiliza el correo electrónico donde se recogen las instrucciones de primer inicio y cambio obligatorio de contraseña, entre otros. En la comunicación se le indicará al usuario que debe cambiar la contraseña la primera vez que ingrese al sistema, que la contraseña que use deberá cumplir con las características de complejidad de esta política, que es intransferible y que es responsable de que esta no sea conocida por terceros.

En aquellos casos que el sistema o aplicación lo permita, se aplicarán los controles necesarios para que el sistema obligue al usuario a cambiar la contraseña la primera vez que la utiliza.

La contraseña tendrá las siguientes características:

- Longitud mínima de 12 caracteres y al menos:
  - Mayúsculas (de la A - Z).
  - Minúsculas (de la a - z).
  - Números (del 0 al 9).
  - Caracteres no alfanuméricos (por ejemplo, !, $, #, %).
- Vigencia máxima de la contraseña: 180 días.
- Vigencia mínima de la contraseña: 0 días.
- Historial de contraseñas: 6 contraseñas.
- Requerimiento de complejidad habilitado.
- Almacenamiento de contraseñas usando un gestor de contraseñas
- La contraseña NO deberá tener el nombre del usuario.
- La contraseña no debe ser igual que alguna contraseña personal del usuario

Los Sistemas de Información usarán un método de enmascaramiento para evitar que la contraseña quede visible en la pantalla mientras el usuario la introduce.

La organización concienciará a los usuarios para que usen contraseñas robustas, evitando el uso de palabras contenidas en un diccionario o cualquier otra información que se pueda relacionar con el usuario en la conformación de las contraseñas a fin de evitar su adivinación.

A fin de evitar ataques de fuerza bruta la cuenta se bloqueará después de cinco (5) intentos consecutivos de inicio de sesión fallidos, activando un bloqueo temporal de 30 minutos. Tras pasar el tiempo de bloqueo, el sistema debería permitir volver a intentar el acceso, en caso contrario, el usuario deberá reportar la incidencia al incidencias@spikatech.com

No está permitido el uso de contraseñas en procedimientos automáticos de conexión como, por ejemplo, la realización de respaldos.

Los reinicios de contraseña por parte del área de ciberseguridad sólo se cursarán después de verificar que quien hace la solicitud es el propietario legítimo de la cuenta o un supervisor autorizado. En este último caso deberá estar documentado en el ticket el motivo por el cual se adopta la medida.

Autenticación multifactor:

Para incrementar el nivel de seguridad, es obligatorio el uso de autenticación multifactor en los accesos externos a los servicios digitales.

La autenticación multifactor (MFA) es un mecanismo para incrementar la seguridad en la identificación de usuarios, de forma que al uso habitual de usuario y contraseña, se suma la necesidad de aportar algún código adicional de seguridad que se puede obtener, por ejemplo, a través de una aplicación móvil.

Se trata de asegurar que el que está accediendo es el usuario autorizado, y no otra persona que intenta usurpar su identidad.

Para este segundo factor de autenticación se recomienda la aplicación móvil Microsoft Authenticator, que es el método más práctico. Como alternativa, o adicionalmente, se podrá configurar un número de teléfono para recibir un SMS, una llamada,.

Mantenimiento de la contraseña por parte del usuario:

Cada usuario de los sistemas de información tendrá una cuenta asociada en aquellos sistemas de información que necesite para el desarrollo de sus funciones, con los privilegios y roles asignados en base a las necesidades de su puesto.

El usuario asociado a las credenciales, identificador y contraseña, siempre es el responsable de las acciones que se realicen con ellas:

- El usuario tiene la responsabilidad de proteger sus contraseñas y mantener su confidencialidad. No se permite compartir las contraseñas o revelar a terceros mismo en el caso de una ausencia prolongada (bajas, vacaciones, etc.).
- Las contraseñas no deben almacenarse en ningún medio legible o visible; no se deben escribir en papel, como tampoco en ficheros electrónicos sin medidas de seguridad, ni directamente, ni con métodos de asociación que habían podido provocar deducirlos de una manera sencilla. Se puede utilizar software especialmente diseñado como gestores de contraseñas, que permiten almacenar nuestras contraseñas encriptadas.
- No se deben usar mecanismos que completen o recuerden las contraseñas.
- Caducidad de la contraseña. Para mitigar ataques de phishing, malware o intentos de obtención de la contraseña reiterados el largo del tiempo, resulta una buena práctica cambiar la contraseña periódicamente.
- Ser cautelosos a la hora de elegir y utilizar las contraseñas:
    - Utilizar contraseñas únicas para servicios importantes, evitando que el compromiso de una cuenta afecte a la seguridad del resto.
    - No elegir contraseñas “comunes” incluidas en el diccionario o en ficheros de diccionarios de contraseñas.
    - No incluir datos propios como parte de la contraseña.
    - No almacenar contraseñas en medios poco seguros.
- Cuando el usuario olvide o sospeche que la seguridad de su contraseña pueda encontrarse comprometida o sospeche que sus credencias puedan estar siendo utilizadas de manera ilegítima, deberá modificar su contraseña de manera inmediata e informar al área de ciberseguridad para el registro de la incidencia.
- Aquellos usuarios que sean administradores de sistema o desarrollen un rol técnico, deben tener en cuenta que todas las contraseñas por defecto de los sistemas o aplicaciones nuevos deberán ser cambiados antes de su paso a producción. Además, periódicamente deberá procederse a su cambio.

4 REFERENCIAS

- ISO/ IEC 27001:2022
    - 5.16 Gestión de identidad.
    - 5.15 Control de acceso.
    - 5.18 Derechos de acceso.
    - 8.2 Gestión de privilegios de acceso.
    - 8.5 Autenticación segura.